

PKI:Securing Your Digital World

ACM SIG Cyber

Agenda

- What & Why PKI
- PKI Components
- Asymmetric Cryptography
- Symmetric Cryptography
- PKI Scenarios
- Everyday use of PKI

What is Public Key Infrastructure (PKI)?

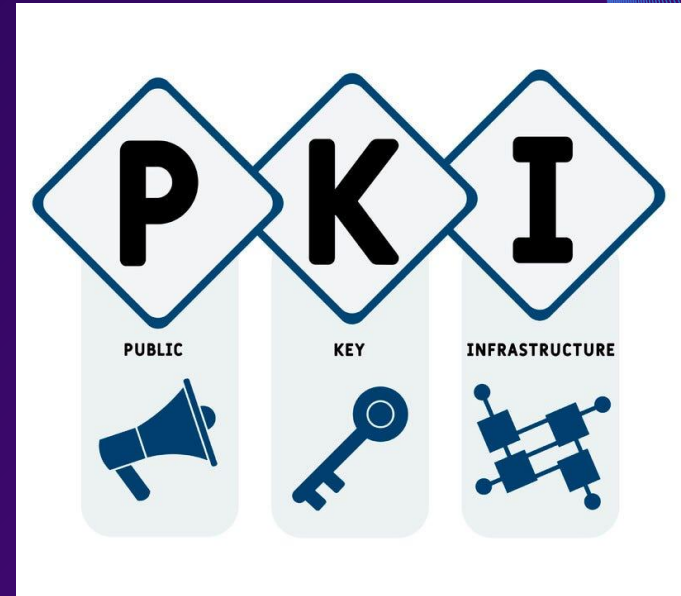
PKI is a system of processes, technologies, and policies that allow you to encrypt and sign data.

PKI provides:

- Secure communication through encryption
- Authenticate the identity of users, devices or services
- Data integrity across the internet.

PKI is used in:

- as SSL/TLS for secure web browsing
- Secure email communication
- Wi-Fi, and VPNs just to name a few.



Asymmetric Cryptography

PKI is built on Asymmetric Cryptography or Public Key Cryptography. It uses two different keys, a Public and a Private. The public key is used to encrypt the message and the private key is used to decrypt it. This ensures secure communication between users, devices, and services.

Public Key

A public key is used to encrypt a message. This key is accessible to anyone.

Private Key

A private key is used to decrypt a message. This key is only shared with the key initiator.

What is a Public and Private Key?

- **Both Public and Private keys are just files** that contain a large sequence of numbers generated using cryptographic algorithms
- The **keys are encoded in base64 in PEM** format which includes a header and footer. Base64 is used for portability. Base64 encodes a string of numbers into textual characters.

Public Key (e.g. id_rsa.pub)

```
-----BEGIN RSA PUBLIC KEY-----  
MIIBigKCAyEA1D/fCz0gVPxDRNEq2t9ha+r0ddTejMYM0le7DkcI  
[...snip...]  
OclIOqt/QgJJAgMBAAE=  
-----END RSA PUBLIC KEY-----
```

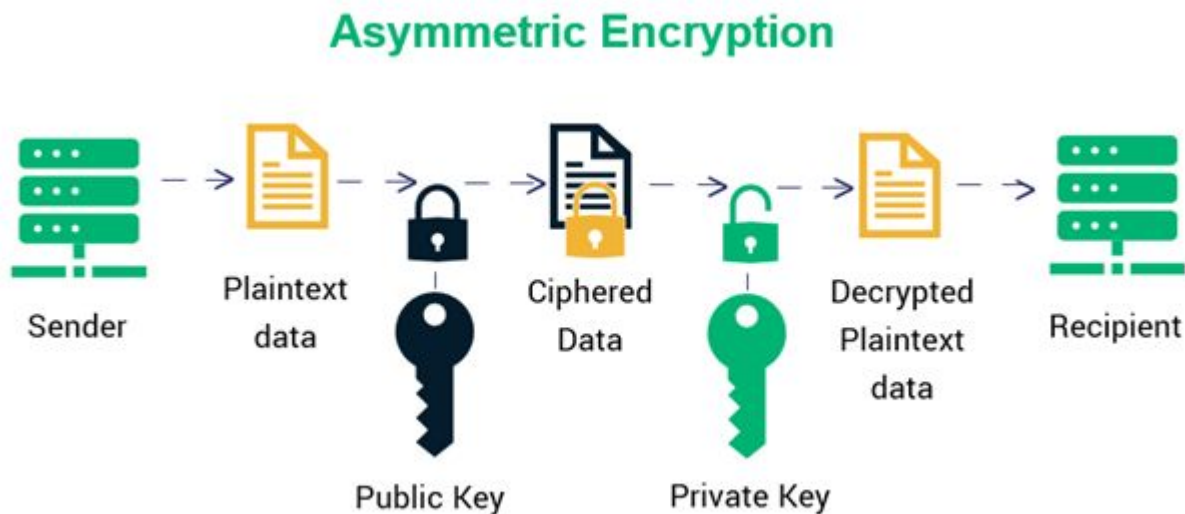
header

Private Key (e.g. id_rsa)

```
-----BEGIN RSA PRIVATE KEY-----  
MIIG4wIBAAKCAyEA1D/fCz0gVPxDRNEq2t9ha+r0ddTe14ztzGFIKc  
[...snip...]  
7dMRxhdyV9ojIOozrGXL6C1x+7NMQ7P2tkNU0+KN8Z67NdO7vOrA  
-----END RSA PRIVATE KEY-----
```

footer

Asymmetric Key Encryption - General Process



Pros:

- Increase data security
- Scalable
- Suitable for Internet data sharing

Cons:

- Complex to setup and maintain
- Resource intensive compared to Symmetric encryption

Using PKI - Alice and Bob Example

- Each person will have two keys a.k.a a Key Pair
 - Public Key - Used for Encryption
 - Private Key - Used for Decryption
- Key pair is mathematically linked
 - Key Pair cannot be derived from the either key
 - Public Key is shared in public on the internet, email, social media
 - Private Key is confidential (secret) - Must be protected



Alice

Alice's Public Key



Alice's Private Key



Public Space



Internet

Bob's Public Key



Bob's Private Key



Bob

Using PKI - Alice and Bob Example continued

- Let assume Alice wants to send a secret message to Bob
- Alice will encrypt the message with Bob's Public Key and send the ciphertext to Bob
- Only Bob's private key can decrypt the message. No other key can decrypt this message. Bob will decrypt the message using his private key to retrieve the original information
- This private/public key encryption approach is called Public Key Cryptography



Bob's Public Key



Bob's Private Key



Bob

This is a secret

Encryption
Algorithm

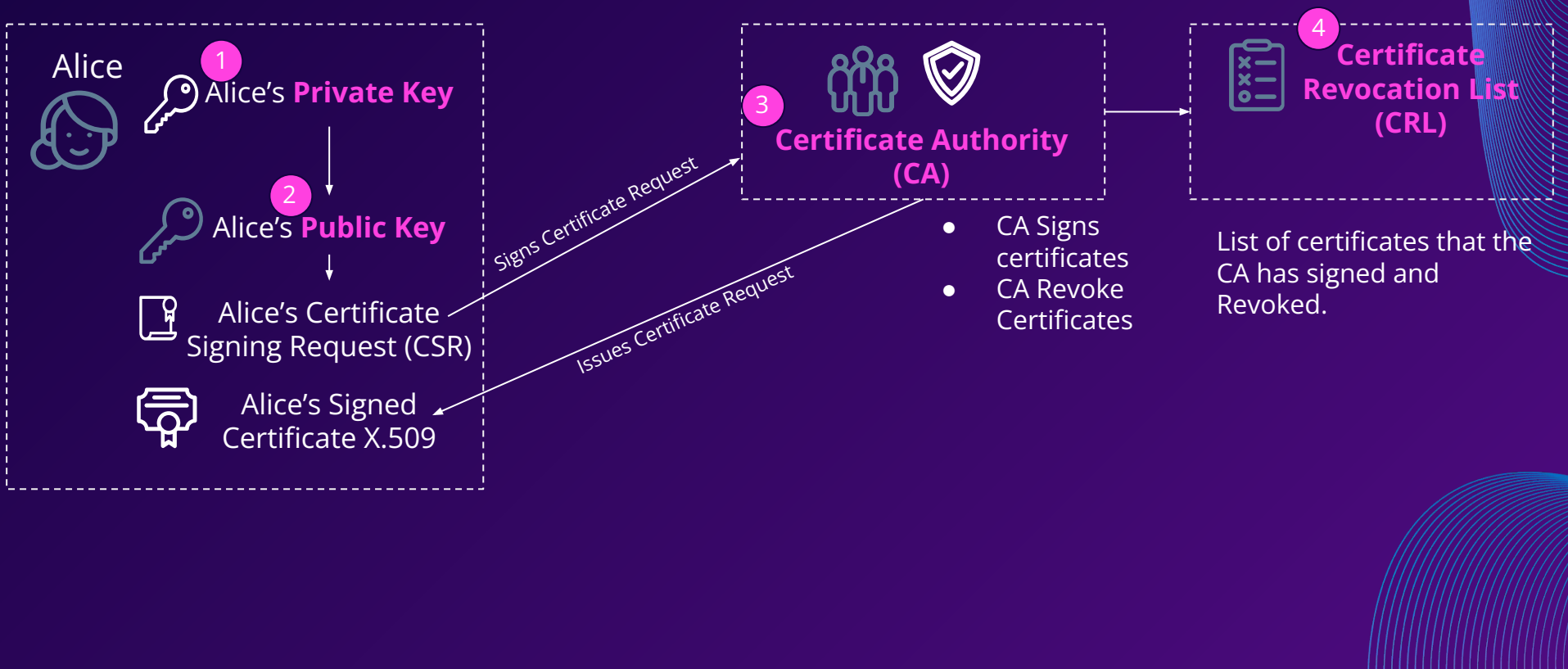
DJ2387GFSHSYE
GDSKSDKSDS09

Ciphertext

Decryption
Algorithm

This is a secret

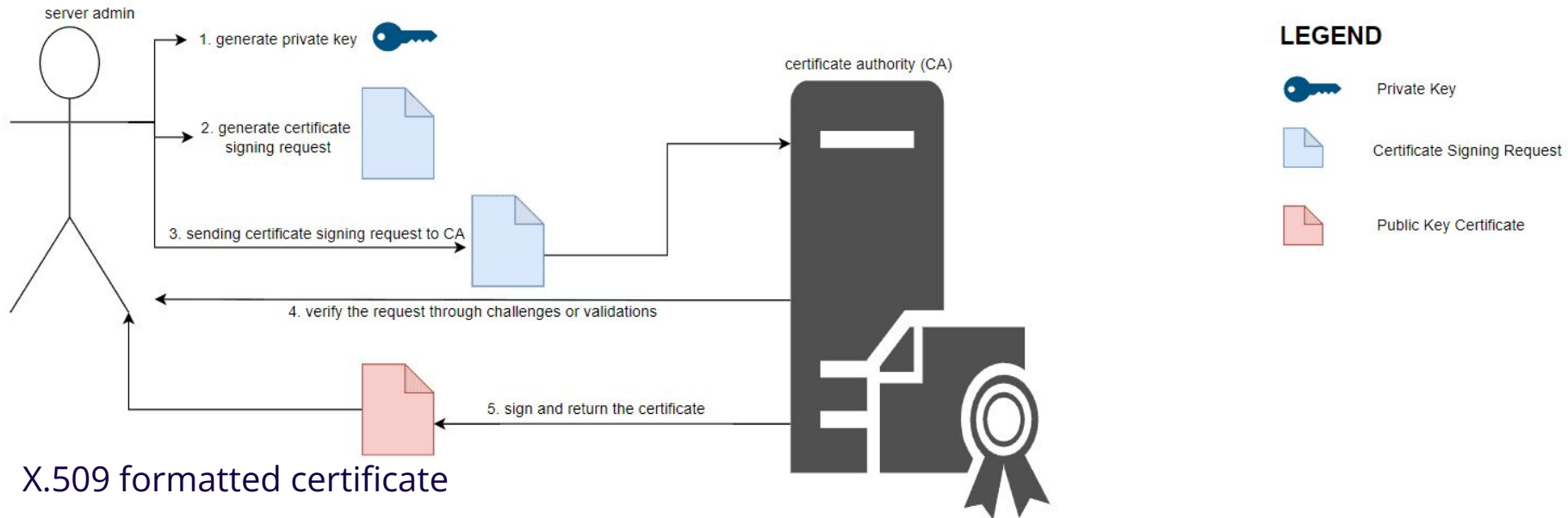
Components of PKI



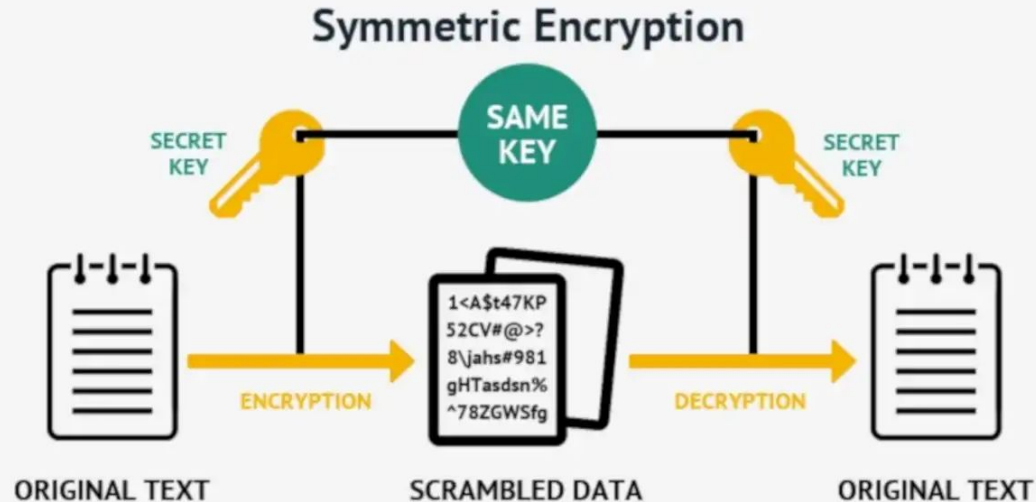
Certificate Signing Request Process from a CA

The signed certificate provides a Trust of authority for the Public key Certificate

Process for Getting Certificate Signed by Authority



Symmetric Key Encryption



Pros:

- Fast
- Efficient - Requires less processing power
- Easy to manage

Cons:

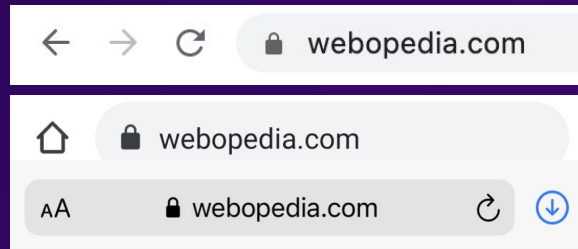
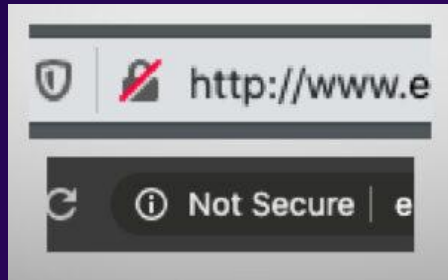
- Less secure
- Not suitable for encrypting large data

Everyday Uses of PKI

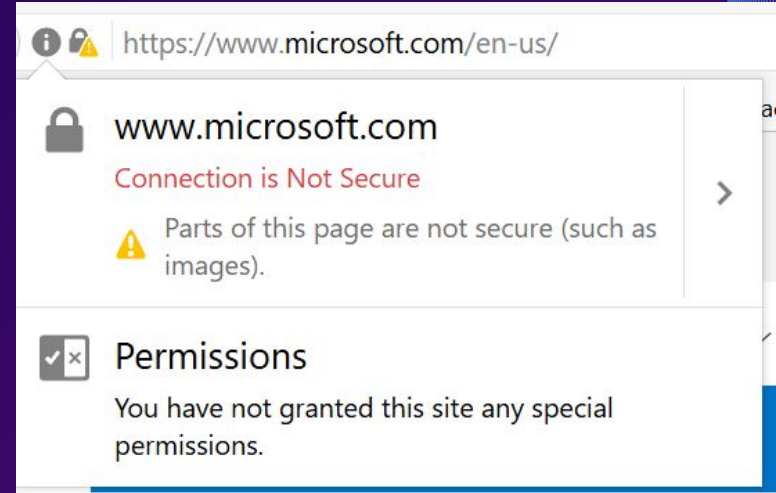
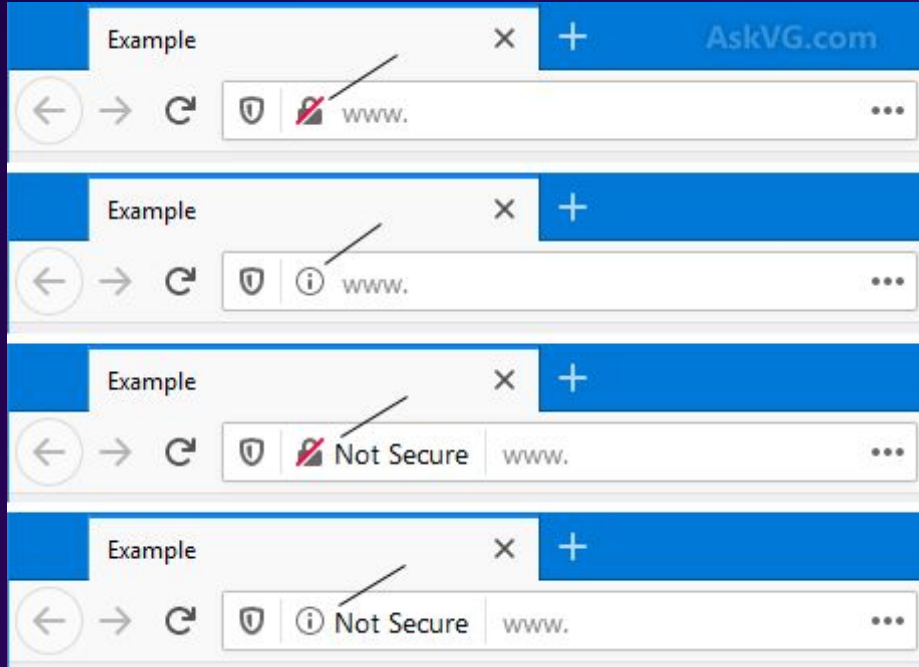
- Internet Web Browsing - HTTPS
- SSH Connections
- Secure Email

Using PKI for Secure Internet browsing

- PKI is used when accessing websites through HTTPS
- HTTPS uses **Secure Sockets Layer (SSL)** or **Transport Layer Security (TLS)** connection
- Ensures that the connection between your browser and the website are secure (encrypted)
- **Very important** when connecting to your online banking or when transmitting Personal Identifiable Information (PII)
- Browsers identify secure connections using the Lock icon in the browser location bar



Non-Secure Browser Indicators

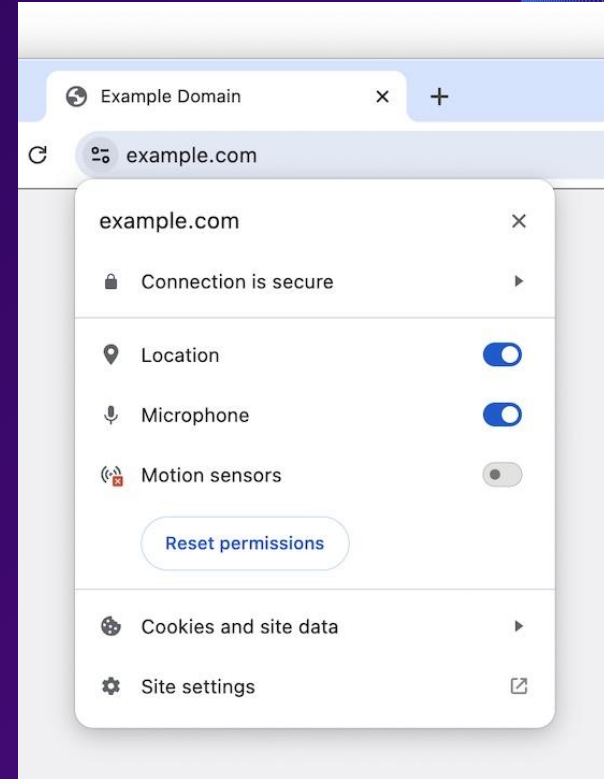


Fact: Chrome Browser replacing Lock Symbol

- The Google Chrome Browser versions 117 and higher have replaced the “Lock Icon” with a new “tune” icon.
- **Reason:** A study showed that many users misunderstand the meaning of the icon
 - The lock icon can be misleading since there are more factors to consider for a “secure” website.
 - Source:
<https://blog.chromium.org/2023/05/an-update-on-lock-icon.html>



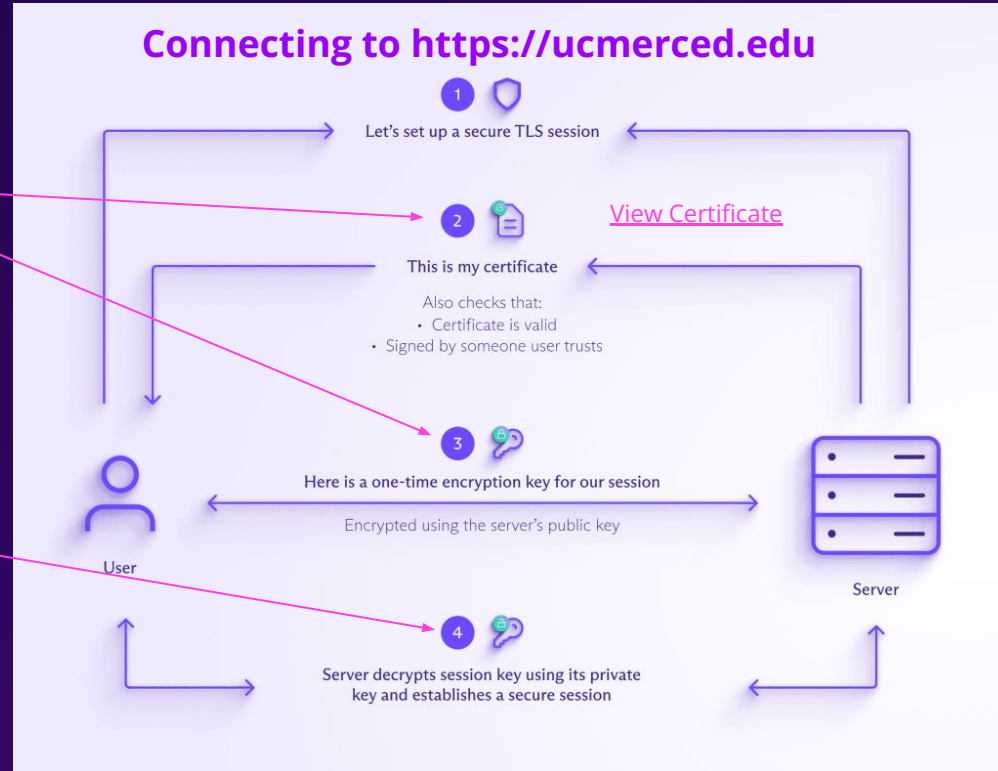
The “tune” icon



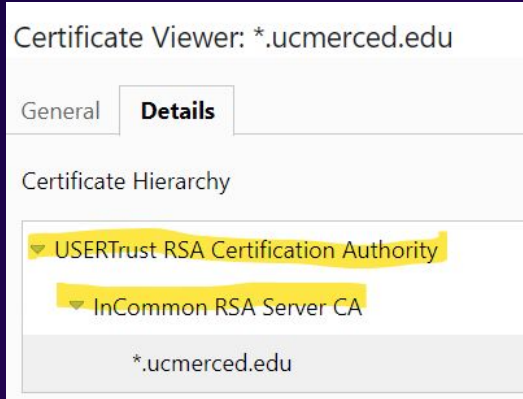
Secure HTTP Connection Sequence

Asymmetric
Cryptography

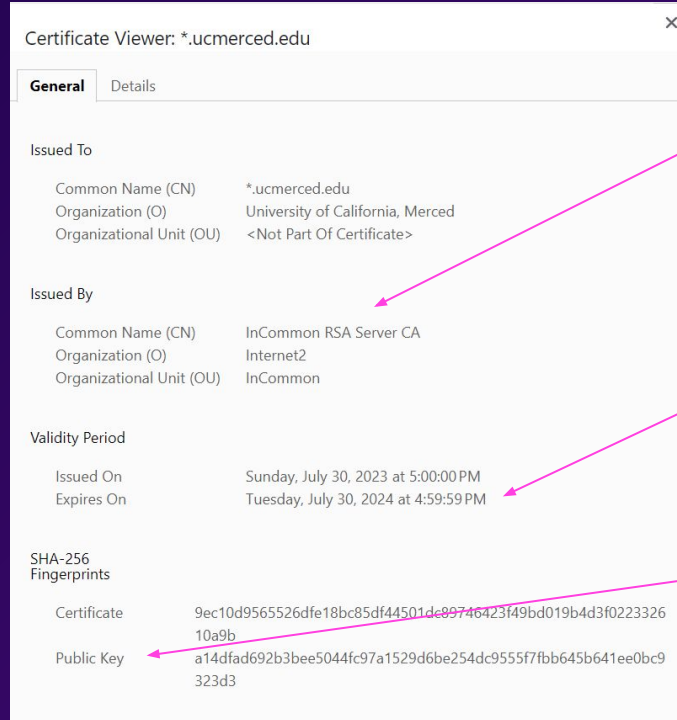
Symmetric
Cryptography



UCMERCED.EDU SSL/TLS Certificate Details



Signing Root CA



Certificate Authority (CA)
that signed certificate

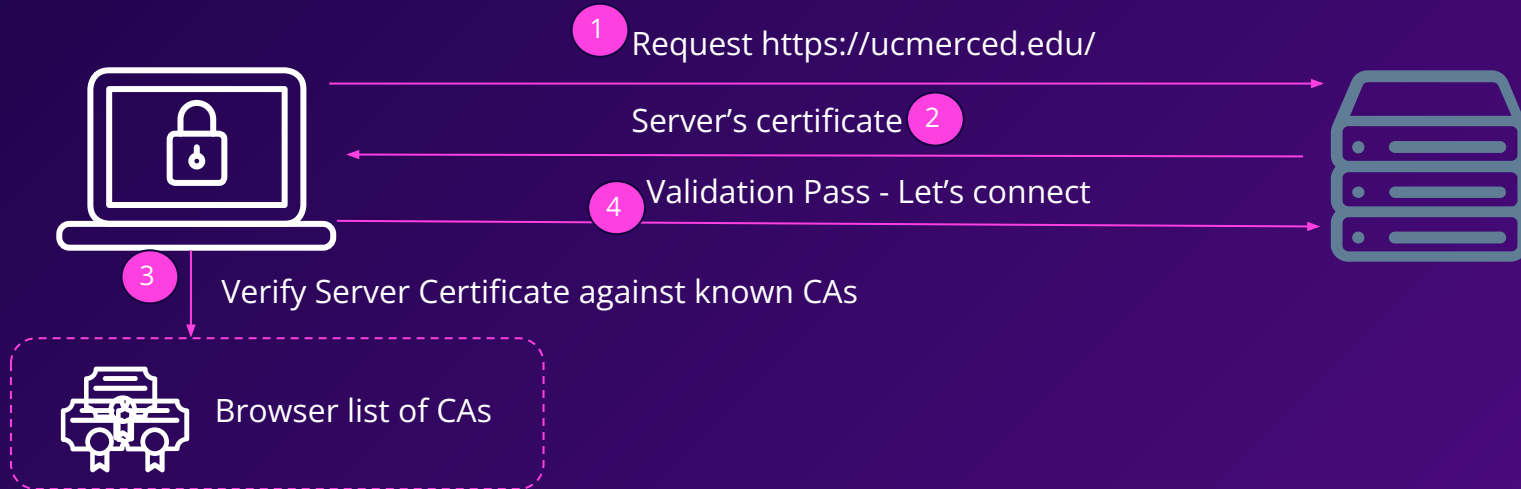
Expiration date of
Certificate

ucmerced.edu
Public Key

X.509 formatted certificate

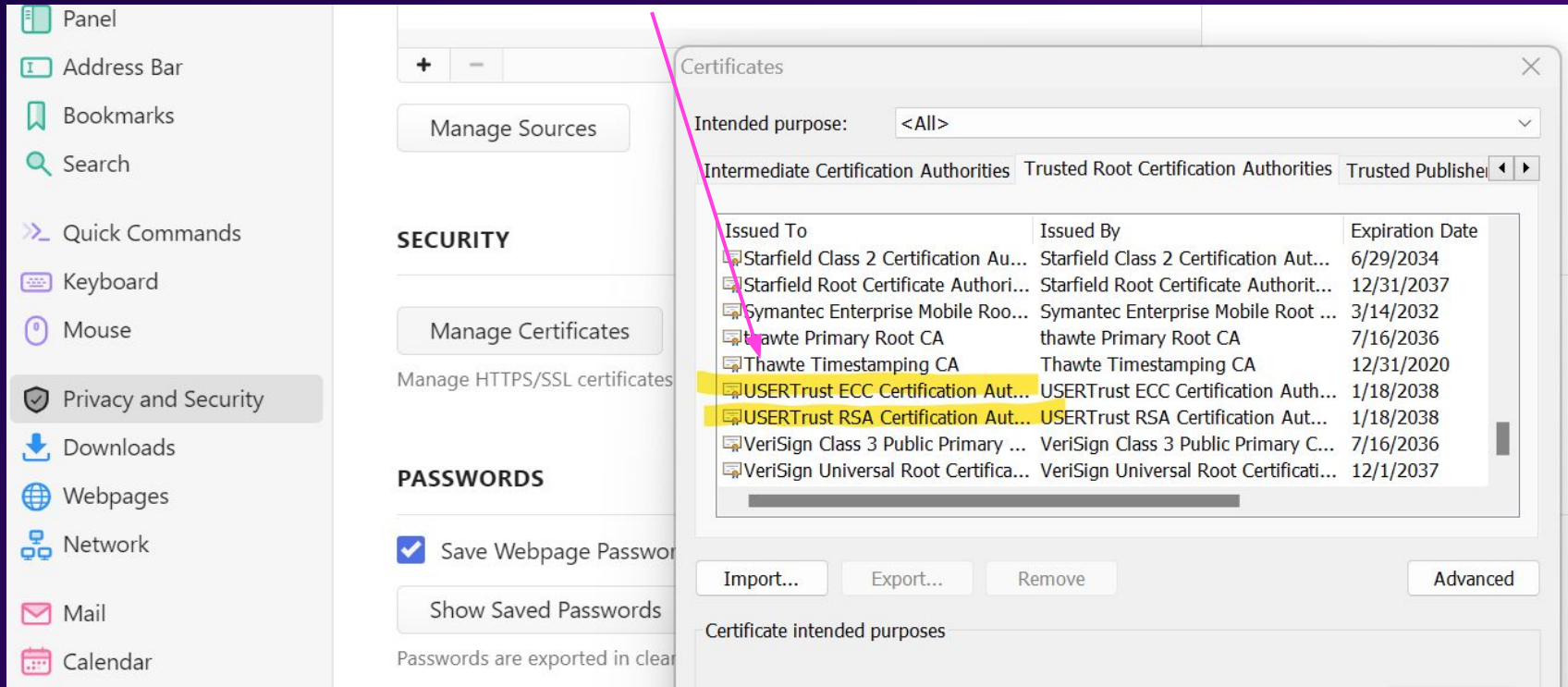
How do Browsers validate a Server Certificate

- All Browsers include a list of known Certificate Authorities
- When a Server provides a certificate to a browser, the browser checks against the list of CA's in it's keystore
- Vivaldi Browser CA Certificate listing:
 - Settings → Privacy and Security → Security → Manage Certificates → Trusted Root Certification Authorities



Browser Trusted CA Certificate Listing

ucmerced.edu Signing CA



The screenshot shows a web browser interface with a sidebar on the left containing various tools like Panel, Address Bar, Bookmarks, Search, Quick Commands, Keyboard, Mouse, Privacy and Security, Downloads, Webpages, Network, Mail, and Calendar. The main content area displays the 'SECURITY' section with a 'Manage Certificates' button. A 'Certificates' dialog box is open, showing a list of trusted root certification authorities. The dialog box has tabs for 'Intermediate Certification Authorities', 'Trusted Root Certification Authorities', and 'Trusted Publishers'. The 'Trusted Root Certification Authorities' tab is selected, and the list shows various certificates including Starfield, Symantec, Thawte, and USERTrust. A pink arrow points from the 'ucmerced.edu Signing CA' text to the 'USERTrust ECC Certification Authority' entry in the list.

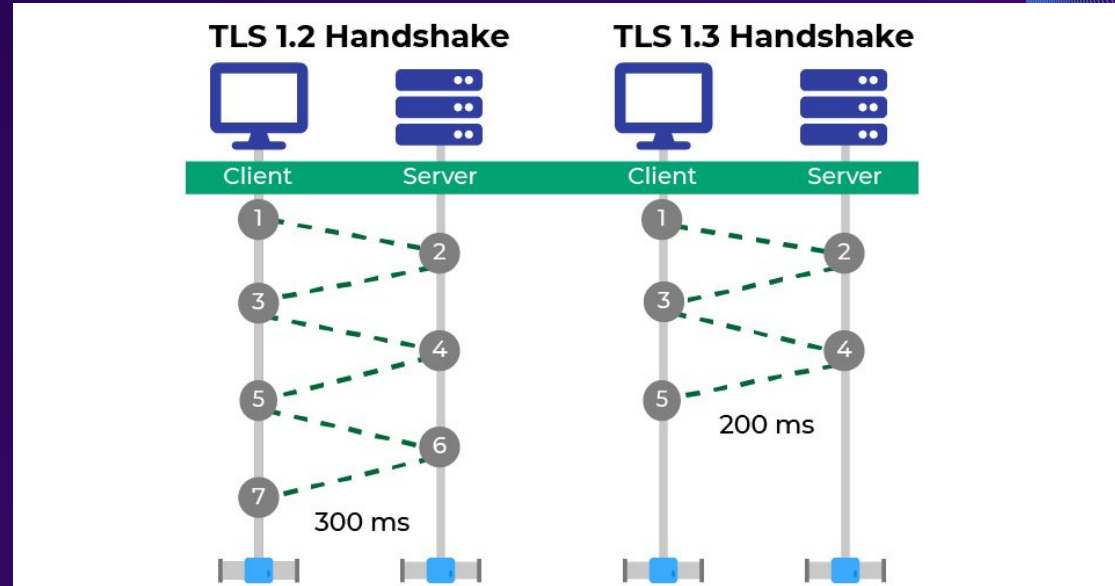
Issued To	Issued By	Expiration Date
Starfield Class 2 Certification Au...	Starfield Class 2 Certification Aut...	6/29/2034
Starfield Root Certificate Authori...	Starfield Root Certificate Authorit...	12/31/2037
Symantec Enterprise Mobile Roo...	Symantec Enterprise Mobile Root ...	3/14/2032
thawte Primary Root CA	thawte Primary Root CA	7/16/2036
Thawte Timestamping CA	Thawte Timestamping CA	12/31/2020
USERTrust ECC Certification Aut...	USERTrust ECC Certification Auth...	1/18/2038
USERTrust RSA Certification Aut...	USERTrust RSA Certification Aut...	1/18/2038
VeriSign Class 3 Public Primary ...	VeriSign Class 3 Public Primary C...	7/16/2036
VeriSign Universal Root Certifica...	VeriSign Universal Root Certificati...	12/1/2037

Buttons: Import..., Export..., Remove, Advanced

Certificate intended purposes

Fact About SSL and TLS

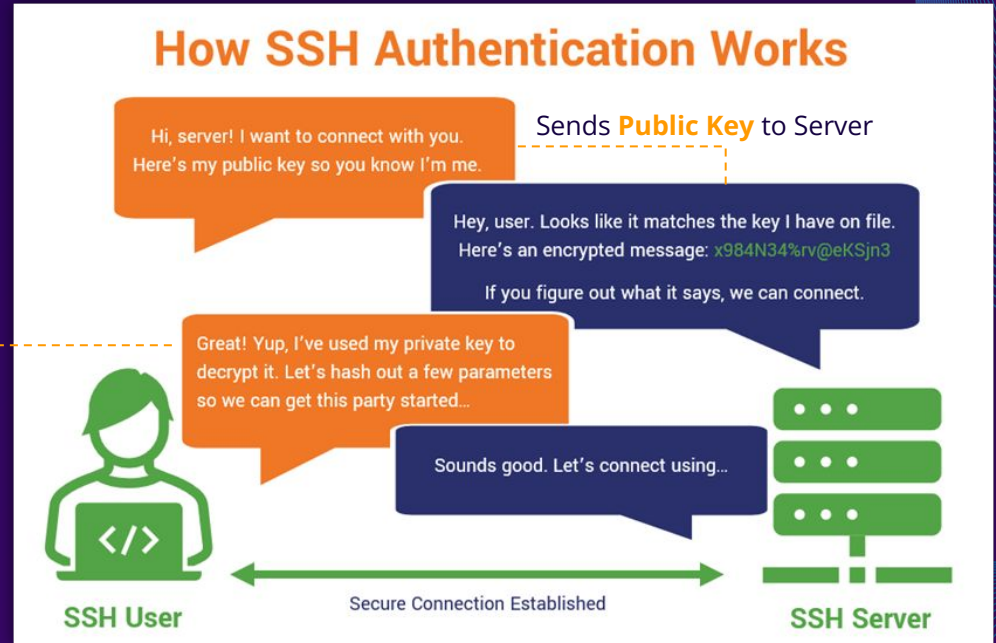
- The term **SSL** has been replaced by **TLS**
 - However, the term SSL is used interchangeably with TLS
- TLS is the upgraded version of SSL that fixes existing SSL vulnerabilities
- SSL and TLS 1.1 are considered insecure. TLS 1.2, TLS 1.3 are currently used on secured systems
- TLS 1.3 was released in 2018
- TLS is used to secure protocols like:
 - HTTPS
 - FTP
 - SMTP (mail)
 - POP3 (mail)



PKI for Secure Remote Connections using SSH

- Secure Shell (SSH) provides secure connection to remote servers
- SSH Public and Private key pairs can be used instead of passwords
- Standard SSH configurations use PKI but without a Certificate Authority - **Reason:** Public and Private keys are controlled by user

Decrypts test message encrypted by SSH Server with SSH User's **Private Key**



SSH Key Setup for Passwordless SSH logins

Local Server

Create Public/Private key pair on local system

🔑 Private Key (~/.ssh/id_rsa)

🔑 Public Key (~/.ssh/id_rsa.pub)

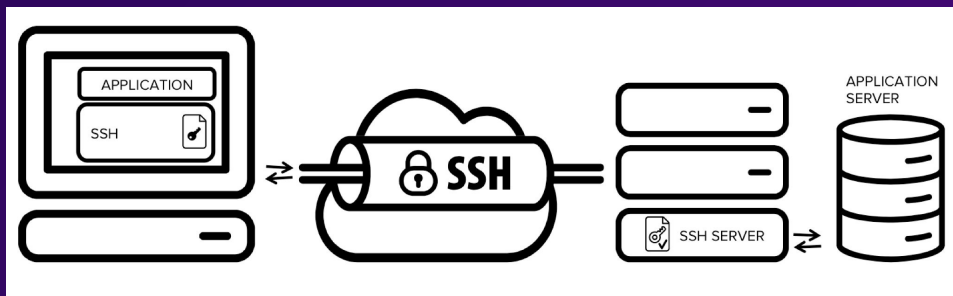
Linux command to generate private/public key pair

```
$ ssh-keygen -t rsa
```

ssh-copy-id -i ~/.ssh/pub.key

Remote Server

🔑 Public Key (~/.ssh/authorized_keys)



Connecting to remote server with default SSH keys - No password

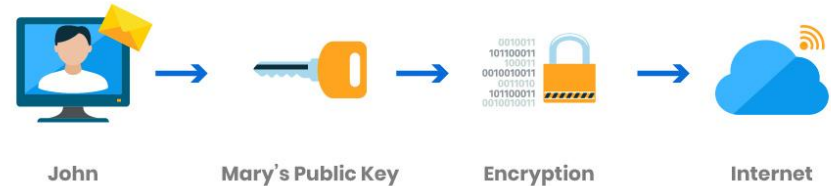
```
local-server$ ssh remote-server  
remote-server$
```

Secure Email

- Secure email uses:
 - S/MIME - Secure/Multipurpose Internet Mail Extensions
 - PGP/MIME - Pretty Good Privacy/MIME
- Secure email uses Public keys to encrypt an email message and a Private key to decrypt the email message
- Accessing web-based email via HTTPS is not the same as secure email**
- S/MIME is supported by Microsoft Outlook, Gmail

Encryption/Decryption

1. John uses Mary's public key to encrypt the email and sends it to Mary.



2. Upon receiving the email, Mary decrypts the email with her own private key.





Questions?
Thank you.

DEMO: Encrypting a file using SSH Keys and OpenSSL

https://cyberpostings.com/pki/encrypt_files_sshkeys.txt